

CISSP Printable Practice Exam 14 - Domain 6 - Security Assessment and Testing

Practice Exam 02 - Domain 6

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP2-099)

Scenario: A logistics company acquired a smaller competitor and connected the acquired identity platform to its enterprise applications. The annual control assessment plan was approved before the acquisition and covers only the original environment.

What should the security assurance manager do FIRST?

- A. Execute the original plan unchanged so year-over-year results remain comparable.
- B. Reassess risk and update the scope, objectives, and procedures for the integrated environment.
- C. Wait for the next annual planning cycle before evaluating the new connection.
- D. Ask the acquired company to certify that its controls are equivalent.

Question 2 (CISSP2-100)

Scenario: An internal auditor is testing change approvals for a year containing thousands of routine changes, a small number of emergency changes, and several changes to critical systems. The auditor cannot inspect every record.

Which sampling approach provides the MOST useful assurance?

- A. Select the first changes recorded in each month because they are easiest to locate.
- B. Use a representative sample and deliberately include higher-risk emergency and critical-system changes.
- C. Review only changes whose owners volunteer supporting evidence.
- D. Inspect only routine changes because they form the largest part of the population.

Question 3 (CISSP2-101)

Scenario: A pharmaceutical distributor is selecting a firm to assess a new security program. One candidate has relevant technical expertise but earns most of its revenue from implementing the same controls it would evaluate.

What is the PRIMARY concern before appointing this firm?

- A. Whether the firm's assessment report will use the distributor's document template.
- B. Whether implementation revenue creates an objectivity threat that cannot be adequately managed.
- C. Whether the firm can complete every test without interviewing control owners.
- D. Whether the firm has previously assessed an organization of identical size.

Question 4 (CISSP2-102)

Scenario: A nonprofit is formalizing its internal security audit function. Auditors previously depended on system owners for permission to inspect records and sometimes had findings suppressed before reaching the board committee.

Which TWO provisions are MOST important to include in the audit charter? Select 2 of the 5 options below.

- A. Unrestricted access to relevant personnel, records, and systems within approved engagements.
- B. Authority for auditors to operate every control they assess.
- C. A functional reporting line that permits significant findings to reach the governing body.

- D. A requirement that system owners approve each finding before it is documented.
- E. Responsibility for accepting organizational risk on management's behalf.

Question 5 (CISSP2-103)

Scenario: A payroll provider's independent controls report covers January through September. A customer is completing a December review and relies on the provider for a critical control. No later report is available.

Which action BEST addresses the uncovered period?

- A. Assume controls remained unchanged because the provider renewed its contract.
- B. Obtain period-specific evidence such as a bridge letter, inquire about significant changes, and perform additional procedures as risk warrants.
- C. Extend the report's end date internally because the underlying service continued operating.
- D. Treat the nine-month report as assurance over the entire calendar year.

Question 6 (CISSP2-104)

Scenario: An airline wants an external team to test segmentation around an operational scheduling environment. Unplanned interruption during peak hours would have severe business impact, but management still requires meaningful evidence of control effectiveness.

What is the BEST assessment strategy?

- A. Prohibit all active testing and rely exclusively on network diagrams.
- B. Perform unrestricted testing during peak operations to maximize realism.
- C. Use approved test windows and techniques, coordinate safeguards, and supplement constrained tests with configuration and evidence review.
- D. Move the target systems outside the audit scope because they are operationally critical.

Question 7 (CISSP2-105)

Scenario: A county agency needs to verify missing patches, local security settings, and installed software across managed servers. Its current unauthenticated scan reports only services visible from the network.

Which change would MOST improve the assessment?

- A. Run an authenticated vulnerability assessment using protected, least-privilege scan credentials where supported.
- B. Increase the number of unauthenticated scans without changing their visibility.
- C. Replace vulnerability testing with interviews of server administrators.
- D. Test only internet-facing ports and infer the condition of local settings.

Question 8 (CISSP2-106)

Scenario: As part of a quarterly assessment, a security analyst must verify that privileged administrative actions are captured completely and forwarded to a protected repository. The task is a scheduled control test, not continuous monitoring.

Which procedure provides the BEST evidence?

- A. Confirm that the logging policy requires privileged events to be retained.
- B. Select authorized administrative actions and trace each event from the source system to the protected repository.
- C. Ask an administrator whether logging is normally reliable.
- D. Count all repository records without linking them to known source events.

Question 9 (CISSP2-107)

Scenario: Automated source analysis of a procurement application identifies common insecure coding patterns. Reviewers are also concerned that a user may divide one purchase into several transactions to bypass an approval threshold.

What should the test lead do NEXT?

- A. Treat a clean automated scan as proof that approval logic cannot be bypassed.
- B. Add manual code and misuse-case review focused on transaction aggregation and authorization logic.
- C. Remove business rules from scope because they are not security controls.
- D. Review only the application's network encryption settings.

Question 10 (CISSP2-108)

Scenario: A property management platform exposes an application interface used by tenants to retrieve their own lease documents. The assessment must verify that tenant identifiers cannot be manipulated to access another tenant's records.

Which TWO tests are MOST relevant? Select 2 of the 5 options below.

- A. Submit a request with another tenant's object identifier while authenticated as a standard tenant.
- B. Measure the color contrast of the tenant portal interface.
- C. Send malformed and boundary-value identifiers to observe validation and error handling.
- D. Confirm that the marketing page is available from the internet.
- E. Compare the number of interface methods with the number of database tables.

Question 11 (CISSP2-109)

Scenario: A financial cooperative's baseline requires portable devices to enforce storage encryption. The compliance test must determine whether the requirement is implemented across the managed fleet.

Which evidence is MOST persuasive?

- A. The approved baseline document stating that encryption is mandatory.
- B. A management console export reconciled to the device inventory, with exceptions investigated and sampled devices verified.
- C. A purchase order showing that encryption-capable devices were acquired.
- D. A training record showing that users were told to protect portable devices.

Question 12 (CISSP2-110)

Scenario: A credit union has already completed a scoped technical penetration test. Leadership now wants to assess whether a realistic, goal-driven adversary can evade detection and whether defenders can identify and contain the activity across multiple attack paths.

Which engagement BEST meets the new objective?

- A. A red-team exercise governed by defined objectives and rules of engagement.
- B. A repeat of the same vulnerability scan with a larger address range.
- C. A documentation review limited to the incident response plan.
- D. A compliance checklist completed by each system owner.

Question 13 (CISSP2-111)

Scenario: A quarterly access certification file contains manager names and completion dates, but every manager approved all listed access within seconds. The audit objective is to

verify that managers performed meaningful reviews.

What is the BEST next step for the auditor?

- A. Accept the completion dates as conclusive evidence of substantive review.
- B. Investigate the anomalous approval pattern and corroborate selected reviews with supporting records and manager inquiry.
- C. Delete the timing data because it may reflect poorly on management.
- D. Conclude that every certified account is inappropriate without further testing.

Question 14 (CISSP2-112)

Scenario: An auditor receives a spreadsheet of security incidents exported by the process owner. The spreadsheet will be used to calculate closure performance, but it excludes several fields and was manually filtered before delivery.

What should the auditor do BEFORE relying on the calculated metric?

- A. Reconcile the extract to the authoritative system and validate filter logic, record counts, and key fields.
- B. Use the spreadsheet because the process owner is accountable for incident handling.
- C. Calculate the metric from only the fastest-closed incidents to reduce outlier effects.
- D. Replace the data with the process owner's estimate of typical performance.

Question 15 (CISSP2-113)

Scenario: A food distributor conducts a tabletop exercise for the loss of its primary warehouse. Participants communicate well, but the exercise reveals that the alternate facility cannot access current supplier data and no owner is assigned to fix the dependency.

How should the result be reported?

- A. As fully successful because participants completed the discussion.
- B. As inconclusive because tabletop exercises cannot identify control gaps.
- C. Against defined exercise objectives, documenting the dependency gap, business impact, owner, and retest requirement.
- D. As a technical vulnerability unrelated to business continuity.

Question 16 (CISSP2-114)

Scenario: A consulting team is collecting configuration exports and screenshots during an external security assessment. Several assessors will analyze the evidence remotely before the final report is issued.

Which TWO practices BEST preserve evidence integrity and traceability? Select 2 of the 5 options below.

- A. Record the source, collection time, collector, and relationship to the test procedure.
- B. Allow each assessor to rename and overwrite original files for convenience.
- C. Protect original evidence from alteration and verify integrity when it is transferred or analyzed.
- D. Remove unsuccessful test results so the evidence set remains concise.
- E. Store evidence in personal accounts until the report is approved.

Question 17 (CISSP2-115)

Scenario: A penetration assessment identified several attack paths. Executives need to decide funding priorities, while technical teams need enough evidence to reproduce and remediate the weaknesses without exposing sensitive details broadly.

Which reporting method is MOST appropriate?

- A. Provide every audience with raw tool output and no prioritization.
- B. Issue only an executive summary and omit technical evidence entirely.
- C. Use a risk-focused executive summary plus access-controlled technical findings with evidence and remediation guidance.
- D. Send exploit details to all employees to demonstrate transparency.

Question 18 (CISSP2-116)

Scenario: An audit found that a legacy laboratory system cannot meet the current authentication standard. An authorized executive accepted the residual risk for six months while a replacement is implemented.

How should the assurance function treat the finding?

- A. Delete it from all records because risk acceptance makes the control effective.
- B. Record the approved acceptance, conditions, and expiration date, then track the finding for reassessment.
- C. Close it permanently because the replacement project has been announced.
- D. Override the executive's decision and certify the system as compliant.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP2-099) - Correct: B

A material integration changes the control environment and risk profile, so the approved strategy must be revalidated before testing. Comparability does not justify ignoring new exposure, delaying assessment leaves a gap, and a management certification cannot replace appropriately scoped verification.

Question 2 (CISSP2-100) - Correct: B

A representative sample supports conclusions about the broader population, while targeted inclusion of higher-risk strata improves coverage of material exceptions. Convenience, voluntary, and routine-only selections introduce bias and may omit the changes most likely to affect risk.

Question 3 (CISSP2-101) - Correct: B

Assessing controls that generate substantial implementation revenue can create a self-interest or self-review threat, so objectivity and safeguards require careful evaluation. Report formatting, avoidance of interviews, and experience with an identically sized organization are secondary to competence and independence.

Question 4 (CISSP2-102) - Correct: A, C

Authorized access to evidence and a reporting line to the governing body enable effective, independent audit work. Operating controls creates a self-review conflict, control owners should respond to findings rather than veto them, and risk acceptance remains a management responsibility.

Question 5 (CISSP2-103) - Correct: B

The customer needs evidence addressing the gap between the report period and its review date. A bridge letter and change inquiry can inform that evaluation, with further procedures based on risk. Contract renewal, internal date extension, or unsupported extrapolation cannot expand the report's actual coverage.

Question 6 (CISSP2-104) - Correct: C

A layered strategy can preserve meaningful verification while respecting operational risk through controlled windows, techniques, coordination, and complementary evidence. Diagrams alone do not prove effectiveness, unrestricted production testing is disproportionate, and excluding critical systems would undermine the assessment objective.

Question 7 (CISSP2-105) - Correct: A

Authenticated assessment can inspect local patch and configuration state that an external network view may not reveal. Repeating the same limited scan does not add needed visibility, interviews are not direct technical evidence, and visible ports cannot reliably establish internal settings.

Question 8 (CISSP2-106) - Correct: B

Tracing known actions end to end tests completeness and successful forwarding using observable evidence. Policy establishes an expectation but not operation, administrator testimony requires corroboration, and an aggregate count cannot show whether required source events arrived intact.

Question 9 (CISSP2-107) - Correct: B

Automated analysis is useful for recognizable coding patterns but may miss context-dependent business-logic abuse. Manual review and targeted misuse cases address how multiple valid-

looking transactions could defeat authorization intent. Network encryption does not test that logic, and a clean scan is not conclusive.

Question 10 (CISSP2-108) - Correct: A, C

Changing an object identifier tests whether authorization is enforced for each requested record, while malformed and boundary values evaluate interface validation and error behavior. Visual design, marketing availability, and raw method-to-table counts do not address the stated access-control risk.

Question 11 (CISSP2-109) - Correct: B

Fleet data reconciled to the authoritative inventory, supported by exception analysis and sample verification, demonstrates implementation and population completeness. A baseline, purchase record, or training record indicates intent or capability but does not prove that encryption is active on required devices.

Question 12 (CISSP2-110) - Correct: A

A red-team exercise emulates a goal-driven adversary and can evaluate defensive detection and response across attack paths, subject to authorization and constraints. A scan identifies potential weaknesses, while documentation and checklist reviews do not exercise the defensive capability against realistic activity.

Question 13 (CISSP2-111) - Correct: B

An implausibly uniform approval pattern calls the quality of review into question. The auditor should investigate and corroborate a sample before concluding. Completion metadata alone may show form rather than substance, while suppressing evidence or assuming every entitlement is invalid would be unjustified.

Question 14 (CISSP2-112) - Correct: A

Metrics are reliable only when the underlying population is complete and accurate. Reconciliation, filter validation, counts, and field checks establish that foundation. Accountability does not replace evidence quality, and selective records or estimates would bias the result.

Question 15 (CISSP2-113) - Correct: C

Exercise performance should be evaluated against planned objectives, and a material dependency failure should become an owned corrective action with follow-up testing. Participation alone does not establish readiness, tabletop exercises can reveal process and dependency weaknesses, and the finding directly affects continuity capability.

Question 16 (CISSP2-114) - Correct: A, C

Documented provenance connects evidence to the procedure and collector, while protected originals and integrity verification support reliable transfer and analysis. Overwriting, selective deletion, and personal storage weaken completeness, custody, access control, and reproducibility.

Question 17 (CISSP2-115) - Correct: C

Layered reporting preserves a consistent risk message while giving each authorized audience the detail needed for decisions or remediation. Raw output lacks context, an executive-only report cannot support technical correction, and broad distribution of sensitive exploit details creates additional risk.

Question 18 (CISSP2-116) - Correct: B

Valid risk acceptance documents a management decision; it does not make the deficient

control effective. The finding should retain its approval, conditions, owner, and expiration for follow-up. A planned replacement does not prove remediation, and assurance personnel do not unilaterally override authorized risk decisions or certify noncompliance as compliance.